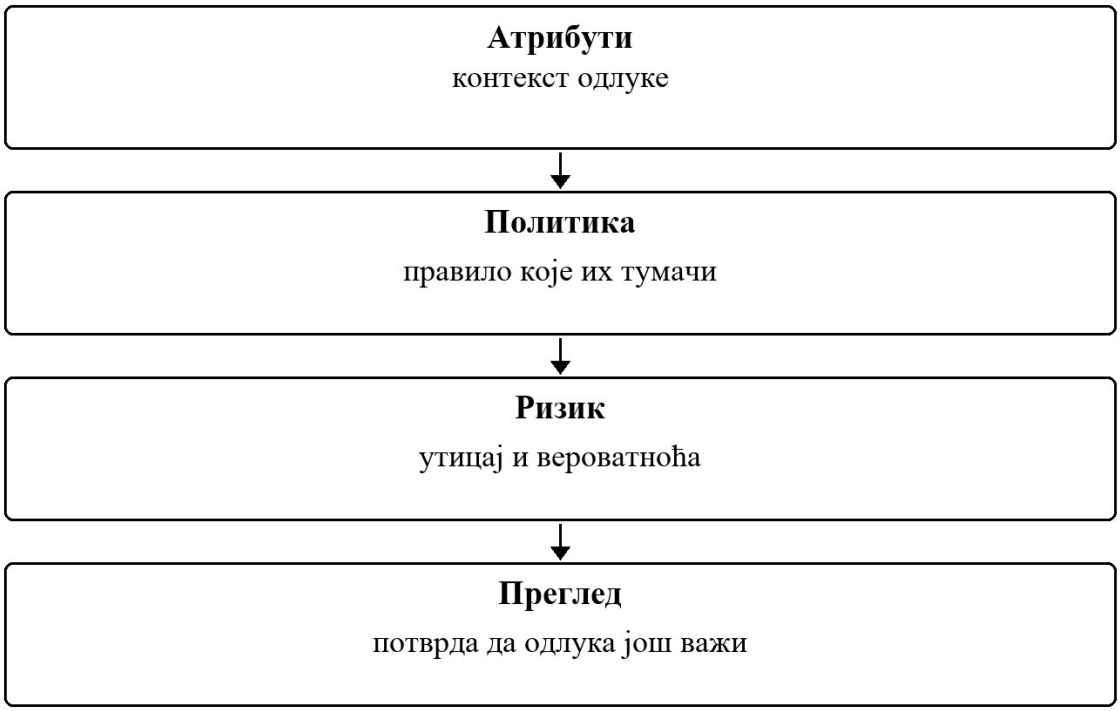
Атрибути, ризик и периодични преглед приступа

Основе информационе безбедности · 07

Контрола приступа заснована на улогама даје стабилну основу, али сложеније одлуке често зависе и од контекста: припадности, врсте података, времена, стања ресурса или нивоа ризика. Атрибутска правила уводе тај контекст без претварања сваке могуће комбинације у нову улогу.

Регистар ризика и редован преглед приступа спречавају да застареле одлуке остану трајне претпоставке. Евидентирају преостали ризик, одговорно лице и рок за поновно разматрање одлуке.



Слика 1. Када улоге више није довољна за добру одлуку

Безбедносна одлука настаје повезивањем приказаних појмова.

Циљ вежбе

Студент треба да образложи одлуку система, податке на којима се она заснива и њен утицај на заштиту података и услуга.

7.1 Право приступа није заувек

Регистар ризика и редован преглед приступа спречавају да застареле одлуке остану трајне претпоставке. Евидентирају преостали ризик, одговорно лице и рок за поновно разматрање одлуке.

- Атрибути се читају из поузданог, јасног контекста.
- Исто стање мора довести до истог резултата политике.
- Ризик укључује имовину, претњу, контролу и преосталу изложеност.

Питање за дискусију

Коју одлуку не бисте смели да заснивате само на улози и који додатни атрибут јој даје смисао?

7.2 Како се ова тема види у развоју

Тим издваја одлуке које не могу поштено да стану у назив једне улоге. Затим их записује као правило које се може тестирати са неколико супротних контекста. Преглед приступа проверава да ли је некадашња пословна потреба и даље стварна.

Честе грешке које треба препознати

- Увођење атрибута без јасног извора и значења.
- Правило које зависи од скривеног стања и даје необјашњив резултат.
- Конфликт дужности откривен тек након што је штета могућа.

Веза са осталим темама

Разматрана одлука повезује идентитет, податке, политике и доказе, а исти поступак анализе примењује се на различите врсте информационих система.

7.3 Пример: иста улога, различит тренутак

Два оператера имају исту улогу, али један ради на инциденту који му је додељен, док други ради на другом домену. Ако политика гледа само улогу, обојица би могла да одобре исту ризичну измену. Атрибути као што су припадност домену, стање инцидента и тренутно одобрење дају одлуци контекст који назив улоге сам не може да носи.

- Атрибутска одлука остаје разумљива само ако је извор сваког атрибута познат и поуздан.
- Правило треба да даје исти резултат за исти снимак контекста, како би могло да се тестира и објасни.
- Преглед приступа враћа тим на питање да ли право и даље има пословни разлог, чак и када је некада било правилно додељено.

Критеријуми решења

Решење треба да буде образложено пословним контекстом, примењено на серверској страни и потврђено поновљивим тестом, ревизијским записом или демонстрацијом.

7.4 Дизајнерска одлука: контекст без хаоса

Атрибути не треба да постану скривени скуп изузетака који нико не разуме. Сваки атрибут мора имати јасно значење, извор и тренутак на који се односи. Политика затим наводи како се ти подаци комбинују, па одлука може бити поновљена, тестирана и објашњена без ослањања на интуицију имплементатора.

- Атрибути се прикупљају из ауторитативних извора, а не из произвољног захтева клијента.
- Правила треба да буду мала и састављена тако да се конфликт може објаснити.
- Контекст одлуке се бележи довољно да каснији преглед разуме резултат без чувања осетљивих детаља.

7.5 Ризик као разговор о одлуци

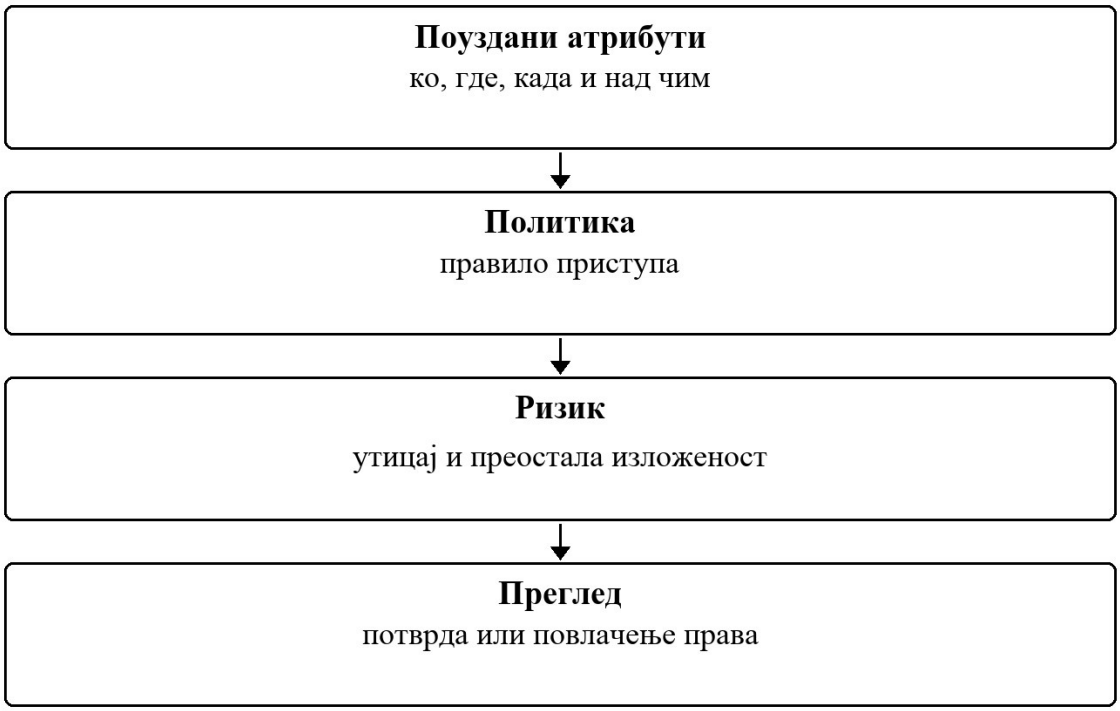
Регистар ризика омогућава поређење утицаја, вероватноће, постојећих контрола и преостале изложености. За прихваћени ризик бележе се одговорно лице, образложење и датум наредног прегледа.

- Ризик повезује конкретну имовину, претњу и контролу.
- Преглед приступа и преглед ризика имају ритам, власника и очекивани исход.
- Сегрегација дужности спречава комбинације права које би једној особи дале превелику контролу.

Самостална провера

За изабрани сценарио наведите одлуку система, коришћене податке, очекивани исход и доказ на основу ког други члан тима може да потврди резултат.

7.6 Шема контекстуалне одлуке



Слика 2. Шема контекстуалне одлуке

Контекст даје прецизност одлуци, а редован преглед проверава да ли одлука и даље има смисла.

За сваки корак шеме одредите покретача, одлуку која се доноси и запис који остаје након извршења.

7.7 Контрола приступа заснована на улогама и АБАЦ у истој одлуци

Табела 1. Приступ и Снага

Приступ	Снага	Ограничење
Контрола приступа заснована на улогама	Јасне, стабилне одговорности.	Тешко изражава време, власништво и стање.
АБАЦ	Користи богат контекст одлуке.	Тражи поуздане атрибуте и читљива правила.
Комбинација	Улога даје основу, атрибути прецизирају.	Потребно је пажљиво објаснити приоритет правила.
СоД	Спречава ризичне комбинације права.	Мора се проверавати кроз ефективна права.

Тумачење поређења

Сваки појам описује посебан део безбедносне одлуке; тек њиховом правилном комбинацијом настаје целовит модел.

7.8 Од ризика до одлуке о прихватању

Ризик се не уклања увек у потпуности. Неке мере би биле прескупе, неке би зауставиле важан рад, а неке зависе од спољне стране. Тада је важно да преостали ризик буде видљив, образложен и временски ограничен, а не заборављен.

1. Описати имовину, сценарио и последицу без општих формулација.

2. Навести постојеће контроле и шта оне заиста покривају.

3. Оценити шта остаје незаштићено након тих контрола.

4. Одредити власника који прихвата ризик и датум следећег прегледа.

Исход учења

Студент треба да уме да изабере одговарајућа питања за анализу безбедносно значајне одлуке и да образложи редослед њихове примене.

Примена на пројекту

На додељеној пројектној целини применити принцип из теме „Атрибути, ризик и периодични преглед приступа". Идентификовати одлуку система, имплементирати је на серверској страни и припремити доказ у облику теста, ревизијског записа или демонстрације.

7.9 Извршиви пример

`RiskBasedAccessPolicy` проверава контекст кроз скуп `IAccessRule` правила. Приступ захтева одговарајућу улогу, уређај, локацију и прихватљив ризик.

Пример 1. Покретање из репозиторијума наставног портала; потребан је дотнет 8 СДК.

```
cd examples/oib-dotnet/vezba-07-abac-rizik-pregled
dotnet run --project src/Oib.Vezba07.ConsoleUi
dotnet test Oib.Vezba07.sln
```

Табела 2. Провера и Садржај

Провера	Садржај
Сценарио	Исправна улога користи се са непознатог уређаја или уз висок ризик.
Тестови	`AccessRuleTests`, `RiskBasedAccessPolicyTests`, `EvaluateAccessHandlerTests`
Доказ	`AccessDecision` даје разлог одлуке; `AccessReviewItem` одређује рок и власника прегледа.

Задатак уз пример

Додати правило радног времена: ограничен ресурс доступан је само радним данима од 8 до 18 часова. Време проследити кроз контекст, а не читати га из система унутар правила.